



COMPUTER SECURITY

Lecture 7: Networks Security

Prof. Dr. Noha Hikal

**Information Technology Dept.
Vice dean for Community Services and Environmental Development**

NETWORK SECURITY PROBLEMS

- **Sharing:** more users and computing systems have access
- **Complexity:** a network may combine two or more dissimilar operating systems with mechanisms for interhost connection
- **Unknown perimeter:** host may be node on multiple networks; unknown or uncontrolled group of possibly malicious users; new hosts may be added to net at any time; user is unaware of potential connections from users of other networks

NETWORK SECURITY PROBLEMS (cont.)

- File may pass through many host machines to get to user
- Administrator of one network domain has no control over other network domains
- There may be many paths from one host to another
- Network users seldom have control over routing of messages

Threats to network communications

Interception

- Unauthorized viewing

Eavesdropping or wiretapping

Modification

- Unauthorized change

Integrity failure

Fabrication

- Unauthorized creation

Integrity failure

Interruption

- Preventing authorized access

Denial of service

Additional NETWORK SECURITY PROBLEMS

- **Privacy:** concealing sensitive data more difficult with many unknown users on a network
- **Integrity:** many nodes and many users, so risk of data corruption is higher. Data corruption includes:
 - modification of messages
 - insertion of bogus messages
 - deletion of messages
 - replay of messages
 - reordering of messages

Additional NETWORK SECURITY PROBLEMS (cont.)

- **Authentication:** hard to assure identity of user on a remote system. Network may not be able to trust authenticity of the hosts themselves.
- **User can't control routing** through hostile or insecure nodes

NETWORK SECURITY SOLUTIONS

- Include traditional host solutions
- In addition to physical, administrative, legal...
- Encryption
- Authentication
- Access Controls

Reconnaissance

A clever attacker investigates and plans before acting. He begins preparation by finding out as much as possible about the target. Some techniques to collect information are:

- **Port Scan**
- **Social Engineering**
- **Artificial Intelligence**
- **OS and Application Fingerprinting**
- **Bulletin Boards and Chats**
- **Availability of Documentation**

The best defense against reconnaissance is silence. Give out as little information about your site as possible, whether by humans or machines.

Threats in Transit

Eavesdrop implies overhearing without expending any extra effort. E.g. a system administrator is eavesdropping by monitoring all traffic passing through a node. The administrator might have a legitimate purpose, s.a. watching for inappropriate use of resources **or** passing files to an enemy from a military computer.

Wiretap means intercepting communications through some effort.

- **Passive wiretapping** is just "listening," much like eavesdropping.
- **Active wiretapping** means injecting something into the communication, s.a. changing the message.

*** Wiretapping works differently depending on the communication medium used.

Threats in Transit

- Protocol Flaws
- Impersonation
- Spoofing
 - **masquerade**: one host pretends to be another.
 - **Session hijacking** is intercepting and carrying on a session begun by another entity.
 - **Man-in-the-Middle Attack** in which one entity intrudes between two others.

Message Confidentiality Threats

- Eavesdropping and impersonation attacks can lead to a confidentiality or integrity failure.
- Other vulnerabilities that can affect confidentiality are misdelivery, exposure, and traffic flow analysis

Message Integrity Threats

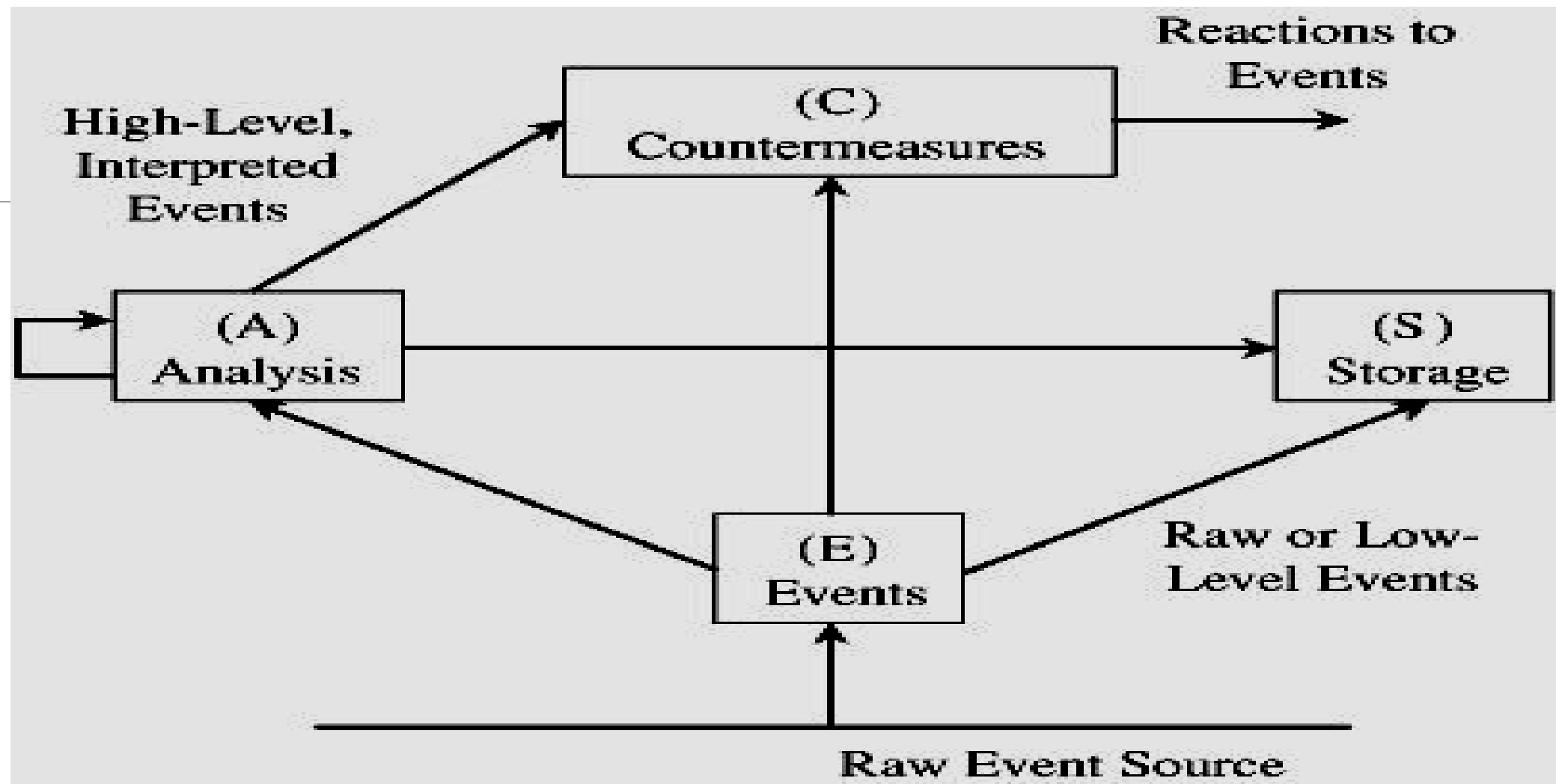
- **Falsification of Messages**
- **Noise**
- **Format Failures**
- **Malformed Packets**
- **Protocol Failures and Implementation Flaws**

Intrusion detection System (IDS)

Is the process of detecting and identifying unauthorized or unusual activity on the system, Such a scheme requires specification of what constitute an undesirable activity and a means of automatically detecting such activity as it occurs.

An **intrusion detection system (IDS)** is a device, typically another separate computer, that monitors activity to identify malicious or suspicious events.

An IDS receives raw inputs from sensors. It saves those inputs, analyzes them, and takes some controlling action.



Common components of an intrusion detection framework

IDSs perform a variety of functions:

- monitoring users and system activity
- auditing system configuration for vulnerabilities and misconfigurations
- assessing the integrity of critical system and data files
- recognizing known attack patterns in system activity
- identifying abnormal activity through statistical analysis
- managing audit trails and highlighting user violation of policy or normal activity
- correcting system configuration errors
- installing and operating traps to record information about intruders

Types of IDS

Signature-based intrusion detection systems perform simple pattern-matching and report situations that match a pattern corresponding to a known attack type.

Heuristic intrusion detection systems, “anomaly based” build a model of acceptable behavior and flag exceptions to that model; for the future, the administrator can mark a flagged behavior as acceptable or not so that the heuristic IDS will now treat that previously unclassified behavior as how it was classified.

Heuristic IDS

Denning's IDS model

Format	Example
Subject	Jhon (action initiator)
Action	File write
Object	Employee record file
Exception condition	No
Resources usage	10
Time stamp	0800 02112010

Heuristic IDS (cont.)

Profiles characterize the normal behavior of the subjects on an objects so the IDS can detect the abnormal.

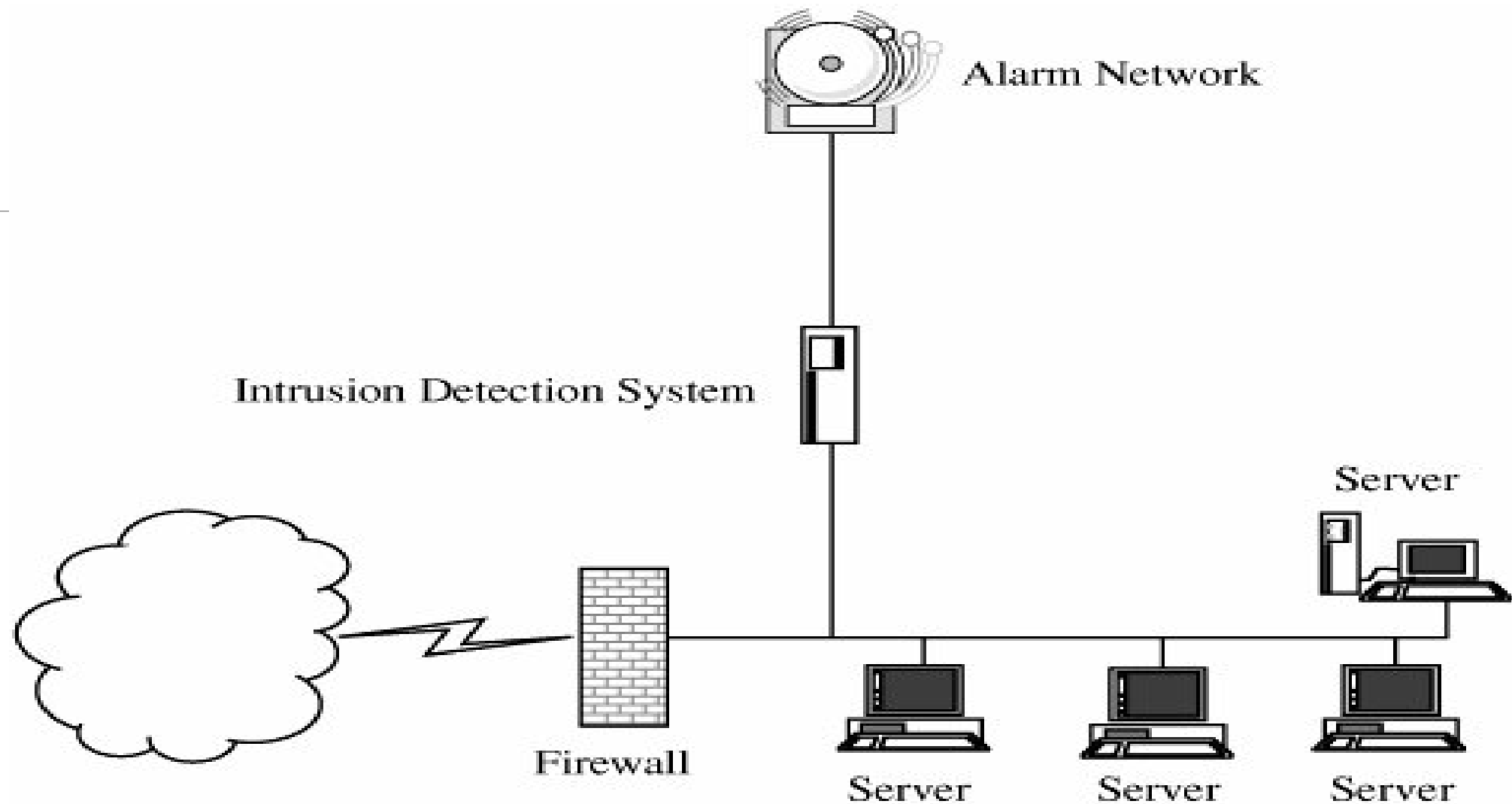
Three candidates profiles:

1-logon and session activity

2-command or program usage

3-file access activity

Anomaly record is created when abnormal behavior appears, it consists of “*event, time, profile*”



Stealth Mode IDS Connected to Two Networks.

Intrusion detection devices can be :

-A network-based IDS is a stand-alone device attached to the network to monitor traffic throughout that network.

-A host-based IDS runs on a single workstation or client or host, to protect that one host.

Early intrusion detection systems [DEN87b, LUN90a, FOX90, LIE89])

Other IDS Types

The **tripwire program** [KIM98] is the most well known software (or static data) comparison program.

System vulnerability scanners, such as **ISS Scanner or Nessus**, can be run against a network. They check for known vulnerabilities and report flaws found.

A **honey pot** is a faux environment intended to trick an attacker. It can be considered an IDS, in the sense that the honey pot may record an intruder's actions and even attempt to trace who the attacker is from actions, packet data, or connections.

Firewalls

A firewall is a device that filters all traffic between a protected or "inside" network and a less trustworthy or "outside" network.

It needs a security policy.

Working principles:

- Default permit
- Default deny

Designing a firewall must satisfy:

- Always invoked
- Well isolated (separate computer)
- Tamperproof
- Small and simple enough for rigorous analysis

Types of firewalls:

1. Packet filtering gateways or screening routers
2. Stateful inspection firewalls
3. Application proxies
4. Guards
5. Personal firewalls

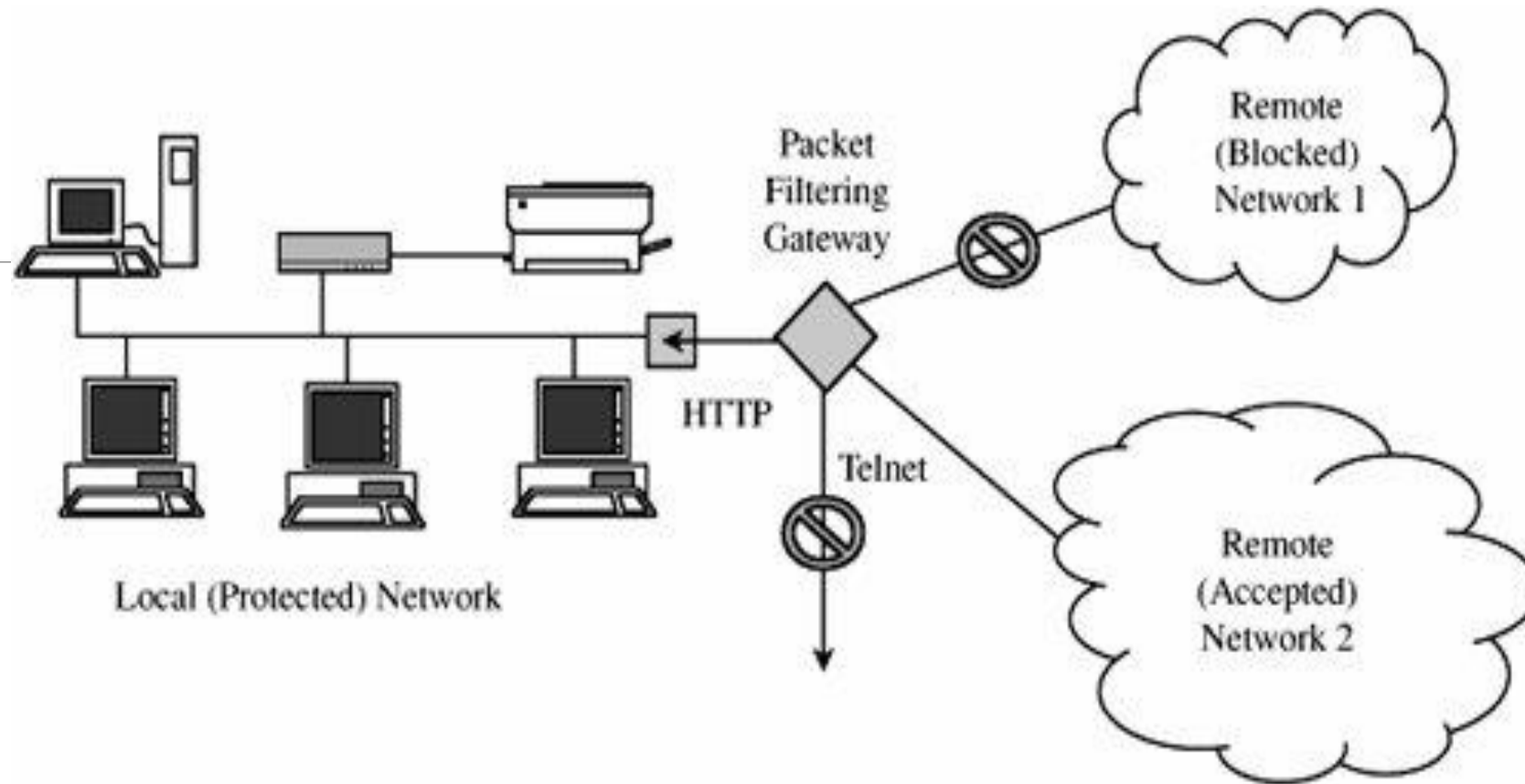
1- Packet Filtering Gateway “screening router”

The simplest, and in some situations, the most effective type of firewall.

Controls access to packets on the basis of packet address (source or destination) or specific transport protocol type (HTTP)

It doesn't see inside the packet, the packet is accepted or rejected based on its IP address.

Disadvantage: filtering rules need to be very detailed



Packet Filter Blocking Addresses and Protocols.

2-Stateful Inspection Firewall

- Works on packets one at a time, accepting or rejecting each packet and moving on to the next.
- The attackers commonly break the attack into multiple packets each have very short lengths that the firewall can't be able to detect the signature of the attack.

3-Application proxy “bastion host”

It intrudes in the middle of a protocol exchange, seeming like a destination in communication with the sender that is outside the firewall, and seeming like the sender in communication with the real destination on the inside. The proxy in the middle has the opportunity to screen the transfers

the proxy interprets the protocol stream to an application, to control actions through the firewall on the basis of things visible *within the protocol, not just on external header data.*

When a proxy gateway can be used?

- A company wants to set up an online price list so that outsiders can see the products and prices offered. It wants to be sure that
 - (a) no outsider can change the prices or product list
 - (b) outsiders can access only the price list, not any of the more sensitive files stored inside.
- A school wants to allow its students to retrieve any information from World Wide Web resources on the Internet. To help provide efficient service, the school wants to know what sites have been visited and what files from those sites have been fetched. particularly popular files will be cached locally.

4-Guard

It acts like proxy firewall, it receives protocol data units,

interprets them, and passes through the same or different protocol data units that achieve either the same result or a modified result.

- The guard decides what services to perform on the user's behalf in accordance with its available knowledge

We call the proxy a guard. Since the security policy implemented by the guard is somewhat more complex than the action of a proxy.

The guard's code is also more complex and therefore more exposed to error..

When a guard firewall can be used?

- A university wants to allow its students to use e-mail up to a limit of so many messages or so many characters of e-mail in the last so many days. Although this result could be achieved by modifying e-mail handlers, it is more easily done by monitoring the common point through which all e-mail flows, the mail transfer protocol.
- A school wants its students to be able to access the World Wide Web but, because of the slow speed of its connection to the web, it will allow only so many characters per downloaded image (that is, allowing text mode and simple graphics, but disallowing complex graphics, animation, music, or the like).

5-Personal firewalls

A personal firewall is an application program that runs on a workstation to block unwanted traffic, usually from the network.

Suitable for home users, individual workers, and small businesses use cable modems or DSL connections with unlimited.

Personal firewalls (cont.)

The personal firewall is configured to enforce some policy. For example:

- The user may decide that certain sites are highly trustworthy, but most other sites are not.
- The user defines a policy permitting download of code, unrestricted data sharing,...

Personal firewalls can also generate logs of accesses, which can be useful to examine in case something harmful does slip through the firewall.

Commercial implementations of personal firewalls include Norton Personal Firewall from Symantec, McAfee Personal Firewall, and Zone Alarm from Zone Labs (now owned by CheckPoint).

Packet Filtering	Stateful Inspection	Application Proxy	Guard	Personal Firewall
Simplest	More complex	Even more complex	Most complex	Similar to packet filtering firewall
Sees only addresses and service protocol type	Can see either addresses or data	Sees full data portion of packet	Sees full text of communication	Can see full data portion of packet
Auditing difficult	Auditing possible	Can audit activity	Can audit activity	Can and usually does audit activity
Screens based on connection rules	Screens based on information across packets in either header or data field	Screens based on behavior of proxies	Screens based on interpretation of message content	Typically, screens based on information in a single packet, using header or data
Complex addressing rules can make configuration tricky	Usually preconfigured to detect certain attack signatures	Simple proxies can substitute for complex addressing rules	Complex guard functionality can limit assurance	Usually starts in "deny all inbound" mode, to which user adds trusted addresses as they appear

Different firewall configurations

Figure 7-38. Firewall with Screening Router.

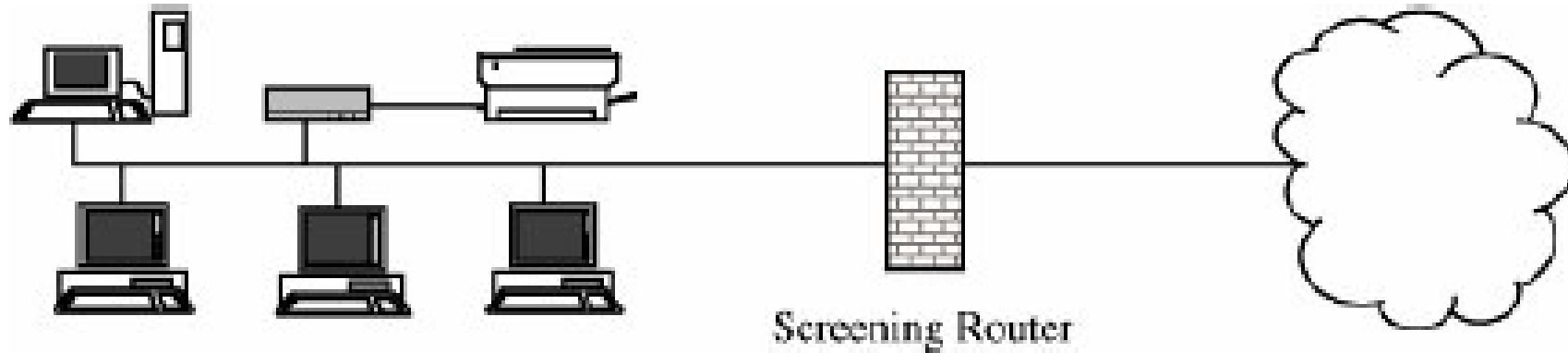


Figure 7-39. Firewall on Separate LAN.

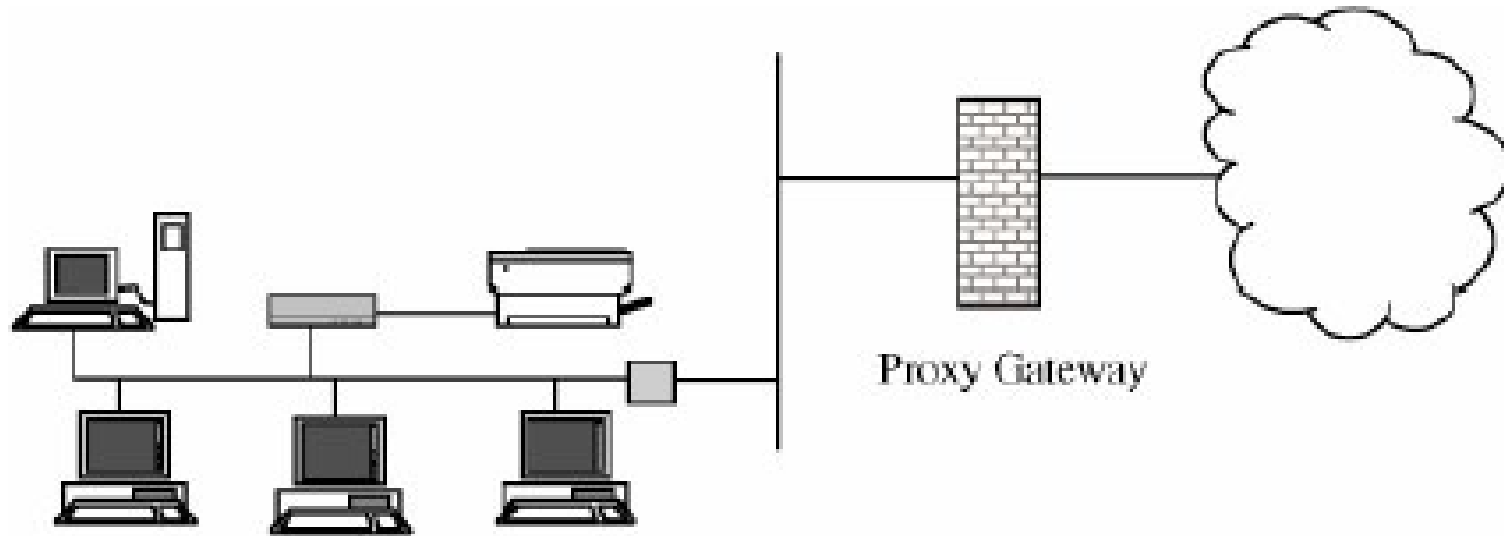
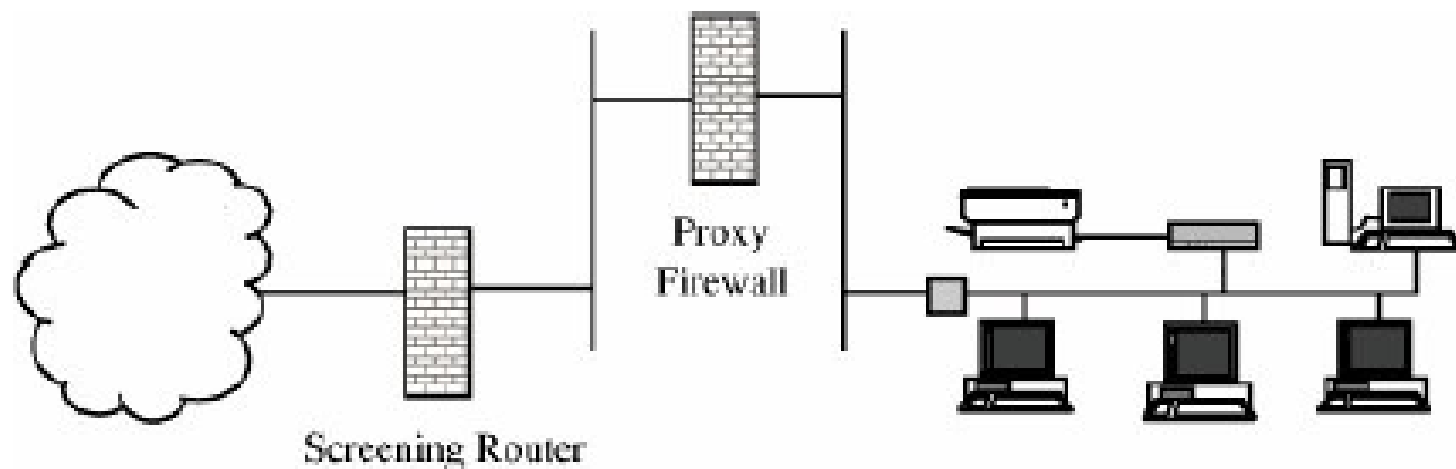


Figure 7-40. Firewall with Proxy and Screening Router.



What Firewalls Can and Cannot Block?

- firewalls **are not complete** solutions to all computer security problems.
- A firewall protects only the perimeter of its environment against attacks from outsiders who want to execute code or access data on the machines in the protected environment.

THANK YOU

